

System & Communications Protection (SC) — CMMC Level 1

SC.L1-3.13.5 · Control Readiness Sheet

0. Control Identity

Practice	“Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.”
Level / Protects	Level 1 · FCI (Federal Contract Information), not CUI
Source	FAR 52.204-21(b)(1)(xiii) · NIST SP 800-171 3.13.5
Objectives	[a] publicly accessible system components are identified; [b] subnetworks for publicly accessible components are implemented; [c] those subnetworks are physically or logically separated from internal networks.

1. Intent

Public-facing components — a web server, a public portal, an email gateway — are exposed to the internet and more likely to be attacked. They belong in a separated zone (a DMZ) so that if one is compromised, the attacker cannot pivot straight into the internal network where FCI lives. The control is about segmentation: keeping the risky, public-facing things away from the trusted, internal things.

2. Ownership

Responsible	Network / System Administrator — designs and maintains the network segmentation.
Accountable	IT Manager / Head of IT — owns the architecture decision and the outcome.

Tailor per client — titles flex; every control has one named, accountable owner.

3. Assessment — how an assessor audits it

- **Examine:** network diagram showing the DMZ/segmentation; firewall rules between the public segment and internal network.
- **Interview:** network/IT staff on how publicly accessible components are isolated from internal systems.
- **Test:** confirm the public segment is actually separated — verify traffic from the DMZ cannot reach internal systems except through controlled paths (obj. c).

4. Evidence to Have Ready

Network diagram identifying public-facing components and the DMZ; firewall/segmentation rules; description of physical or logical separation.

5. Customer Questions

- Do you have any public-facing servers — a website, web app, email server, or portal — that you host yourself?
- If yes, are those separated from your internal network (a DMZ or equivalent), or do they sit on the same flat network?
- Can you show that separation on a network diagram?

6. Not Applicable — Determination

Eligibility: MOST COMMON N/A CANDIDATE at Level 1. This control is genuinely Not Applicable when the organization has no publicly accessible system components within the assessment boundary — for example, a small firm with no self-hosted public servers, whose website and email are fully SaaS/cloud-hosted by a third party. This is the one Level 1 control where N/A is frequently legitimate.

Verbiage: “SC.L1-3.13.5 is Not Applicable. [Organization] operates no publicly accessible system components within the assessment boundary — there are no self-hosted public web, mail, or application servers; public-facing services are provided by third-party SaaS outside the boundary, as shown in the network diagram dated

____. With no public-facing components to isolate, subnetwork separation has no applicable implementation. This determination is re-evaluated if any publicly accessible component is introduced.”

7. Commercial Framework Mapping

Framework	Equivalent control(s)	Called
SOC 2 (TSC)	CC6.6 — boundary protection and segmentation of system components	“Network segmentation”
ISO 27001:2022	A.8.22 Segregation of networks	“Network segregation”

Gap: Low. Same concept as SC.L1-3.13.5. Commercially, segmentation is judged on design adequacy (is the segmentation actually effective?) rather than mere existence, and a SOC 2 auditor expects the firewall rules enforcing it to be evidenced and reviewed periodically.

Access Control (AC) — CMMC Level 1

AC.L1-3.1.22 · Control Readiness Sheet

0. Control Identity

Practice	"Control information posted or processed on publicly accessible information systems."
Level / Protects	Level 1 · FCI (Federal Contract Information), not CUI
Source	FAR 52.204-21(b)(1)(iii) · NIST SP 800-171 3.1.22
Objectives	[a] individuals authorized to post to publicly accessible systems are identified; [b] procedures to ensure FCI is not posted are in place; [c] a content-review process exists; [d] content is reviewed prior to posting to prevent FCI disclosure.

1. Intent

Public systems — your website, social media, a public portal — are visible to anyone. This control makes sure FCI never gets posted to them, whether by accident or by an unauthorized person. The mechanism is a review step: someone authorized checks content before it goes public, so contract information doesn't leak into the open.

2. Ownership

Responsible	IT Administrator + Web/Marketing content owner — whoever publishes to public systems and whoever reviews.
Accountable	IT Manager / Head of IT (or Communications lead) — owns the review process and the outcome.

Tailor per client — titles flex; every control has one named, accountable owner.

3. Assessment — how an assessor audits it

- **Examine:** list of publicly accessible systems; content-review/approval procedure; records of who is authorized to post.
- **Interview:** staff who post public content on who reviews it and how FCI is kept off public systems.
- **Test:** review current public sites/pages for any FCI exposure; confirm the review step actually occurs before posting.

4. Evidence to Have Ready

List of publicly accessible systems; content-review and approval procedure; list of authorized publishers.

5. Customer Questions

- Do you have a public website, portal, or social media that your organization posts to?
- Who is allowed to post, and does anyone review content before it goes public?
- How do you make sure contract information never ends up on a public page?

6. Not Applicable — Determination

Eligibility: CONDITIONAL. N/A only if the organization maintains NO publicly accessible information systems at all within the assessment boundary. This is uncommon — most organizations have at least a website — so confirm carefully before declaring N/A. If a third party fully hosts and controls the public site and the org never posts to any public system, a scoped N/A may be defensible.

Verbiage: "AC.L1-3.1.22 is Not Applicable. [Organization] maintains no publicly accessible information systems within the assessment boundary on which information could be posted or processed, as evidenced by [artifact]. With no public system under the organization's control, the practice has no applicable implementation. This determination is re-evaluated if a publicly accessible system is introduced."

7. Commercial Framework Mapping

Framework	Equivalent control(s)	Called
SOC 2 (TSC)	CC6.6, CC6.7 — controls over information on public/boundary systems	"Data exposure control"
ISO 27001:2022	A.5.14 Information transfer; A.8.23 Web filtering	"Information transfer"

Gap: Low. Same concept as AC.L1-3.1.22. Commercially this widens into data-loss-prevention and public-disclosure controls, and a SOC 2 auditor will look for a documented content-review/approval workflow operating over the review period.